

FROM HARDWARE WALLETS TO OPEN DIGITAL PRIVACY DEVICES

Not your keys, not your coins — and how AI makes DIY signers possible

NICOLAS BACCA (BTCHIP)
Chef, zknox

NOT YOUR KEYS, NOT YOUR COINS

Self-custody only works if the keys stay yours.

Crypto's most famous saying. But what do we actually do to make sure you keep your keys?

1. **Keep them secret**
   Nobody else can read or copy the key.

2. **Keep them safe**
   A backup survives loss, theft and fire.

3. **Keep them usable**
   You can sign every day without exposing them.

If it works for crypto, can we extend it elsewhere?

Passkeys · identity · encrypted messaging · signing documents: the same key-custody problem.

KEY BACKUPS

One mnemonic replaces a drawer full of keys.

HD wallets derive every key from a single seed, and derivation now goes far beyond Bitcoin curves.

Before crypto

- **SSH key**
- **PGP key**
- **TLS certificate**
- **Disk encryption key**
- **2FA secrets**

Each one backed up separately, or not at all.

Since crypto

Mnemonic
24 words · BIP-39

HD derivation
BIP-32 tree: one path per key

- **secp256k1** Bitcoin, Ethereum
- **ed25519** Solana, SSH
- **P-256** passkeys, FIDO
- **RSA** PGP, legacy PKI

THREATS AGAINST KEYS

Attackers go after you, your device, or your intent.

Phishing
targets you

You give away your mnemonic. Very motivated attackers will spend hours on the phone with you.

Dumb malware
targets the device

Steals the key directly from a weak architecture. Mobile is better protected, but not perfect (DarkSword, Coruna).

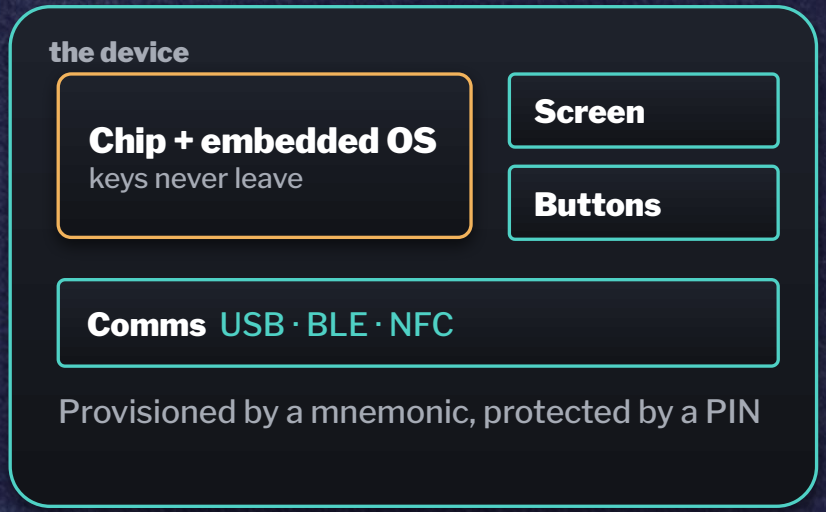
Smart malware
targets your intent

Gets you to approve the action yourself while hiding what it really does. It never touches the key.

POPULAR SOLUTION: HARDWARE WALLETS

Proper name: a hardware signer.

Treat the outside world as hostile and keep a local source of truth, with as few external dependencies as possible.



✓ **What you see is what you sign**
The screen on the device is the only source of truth.

✓ **Efficient against malware**
Malware on the host cannot sign or read the key.

! **Not against phishing**
Nothing stops you from reading your words to an attacker.

THREATS AGAINST THE HARDWARE

Once attackers hold the device, the game changes.

Passive physical attacks

Listen to the electromagnetic noise of the device to deduce secrets.

ML makes this very powerful, and it may not be fixable

Active physical attacks

Alter the execution flow with glitches (voltage, clock) or external elements (laser, EM coil).

Evil maid

Swap your personalised device for a good-enough clone to harvest unlock codes or secrets.

Supply chain attacks

The hardware is tampered with before it ever reaches the user.

How vendors protect their devices

Every protection comes with a tradeoff.

Usually against verifiability, usability or repair.

Tamper-evident packaging

Stickers, or glitter seals such as EntropySeal.

Limit

Stickers can be replaced. Glitter needs specific packaging steps and a knowledgeable user to verify.

Genuine check

Verify a secret provisioned at the factory: the code running on the chip cannot be swapped.

Limit

The scope might not cover the entire device.

Anti-tamper meshes

A circuit that breaks easily if the device is opened or modified.

Limit

Must be powered constantly. Bad for inspection and repair.

ARCHITECTURES: THE CHIPS

Where the code and the secrets live decides everything.

	Physical security	DIY-friendly	Genuineness	
Non-secure chip code + secrets	●○○ low	●●● easy	○○○ weak or none	Easy to impersonate
Secure chip code + secrets	●●● high	●○○ hard	●●● easy	Proprietary, rarely DIY
Non-secure + secure code | secrets	●●○ medium	●●○ yes	●●○ harder	More complex design

ARCHITECTURES: THE SOFTWARE

From one firmware to an app platform.

Monolithic firmware

One firmware for everything. Modify and reflash to add a feature.

hard to add apps · not made to be shared

→

Multiple static apps

Still one firmware, but code is split into apps that cannot be loaded dynamically (e.g. a Python interpreter).

easier to write apps · not made to be shared

→

Multiple dynamic apps

The firmware is an OS that lets users install and remove applications.

apps can be shared

How dynamic apps are isolated from each other

Ledger locks BIP-32 derivation paths per app

Foundation generates a different seed per app

STATE OF THE MARKET TODAY

Mostly closed boxes that are hard to verify.

DIY is the exception

Trezor doable for popular devices, but not encouraged

SeedSigner · Specter DIY · Firefly very niche

The large majority of devices are bought, not built.

Commercial devices are hard to verify

Not made to be opened physically

Genuine check has a limited scope

Tamper-evident packaging is uncommon or poorly implemented

CASES FOR DOING THINGS DIFFERENTLY

Buying a dedicated device creates risks of its own.

Data breaches

Ordering a specific device for a specific use creates risk when the vendor is breached, and the data can be linked through other breaches.

Hardware implants

Seen in the wild, exploiting weak supply chains and device design: an SPI spy plus an eSIM hidden on the screen of a Ledger.

Tivoized devices

Even open devices ship with a locked bootloader that treats vendor-signed images differently. A replaceable bootloader is a risk too.

THE CHIP HOLDING YOUR KEYS CAN NOW BE OPEN

Not your hardware, not your keys.

About $700M was taken from 160,000 personal wallets in 2025, almost none of it by breaking a chip. The chip is simply the one link nobody could check.

- ✓ **Apps & wallets**
- ✓ **Operating systems**
- ✓ **Firmware**
- ? **The secure chip**

Open secure silicon, in products in 2026

TROPIC01 Tropic Square · in Trezor Safe 7

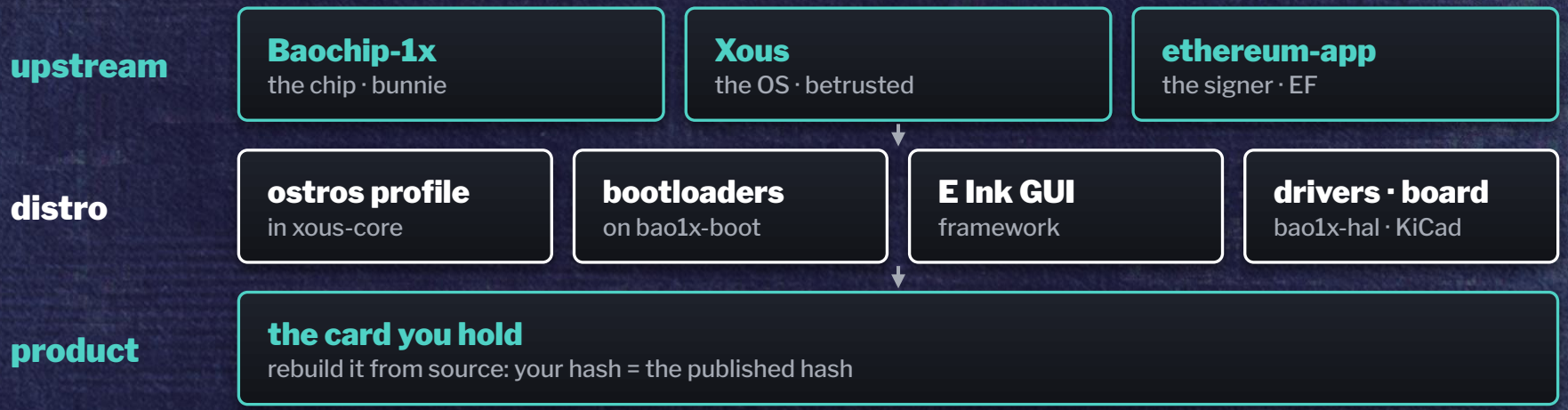
Daric CrossBar + Baochip · in Ostros, DEF CON 34 badge

OpenTitan lowRISC + Google design · Nuvoton silicon · Chromebooks

BUILD HARDWARE THE WAY LINUX IS BUILT

Ostros is a distro. Baochip and Xous are the kernel.

Take the open chip and the open OS upstream, add what the product needs, publish the difference.



forked little, upstreamed most · same kernel, other distros: DEF CON 34 badge, Dabao

Why one open chip is safer than two closed ones

What an open secure chip needs

Each of these is in the published design, where you can check it, not in a datasheet you have to believe.

Crypto off the CPU bus
isolated signing engine

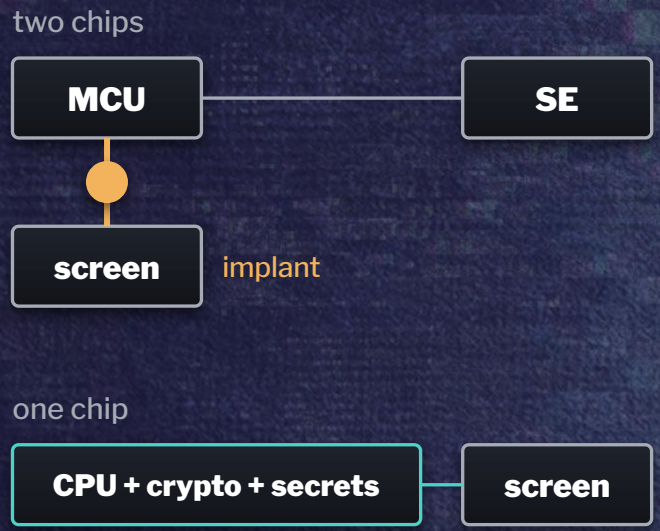
Real memory isolation
MMU, a process per service

Memory that cannot leak
ReRAM: ions, not charge

Visible countermeasures
mesh, glitch, decap sensing

Entropy you can audit
the Coldcard lesson

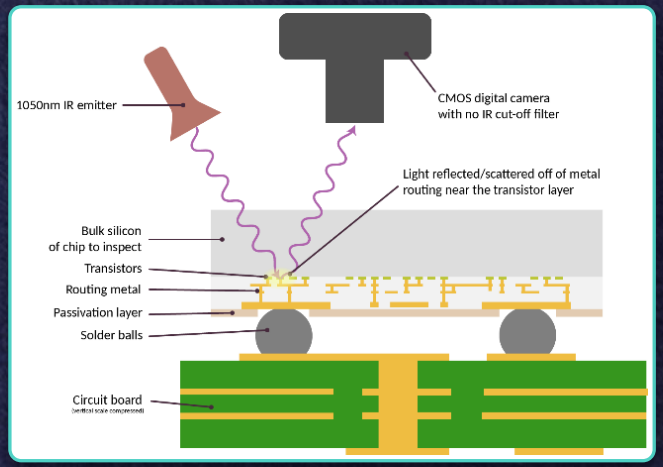
One die, no bus to tap
the Ledger implant lesson

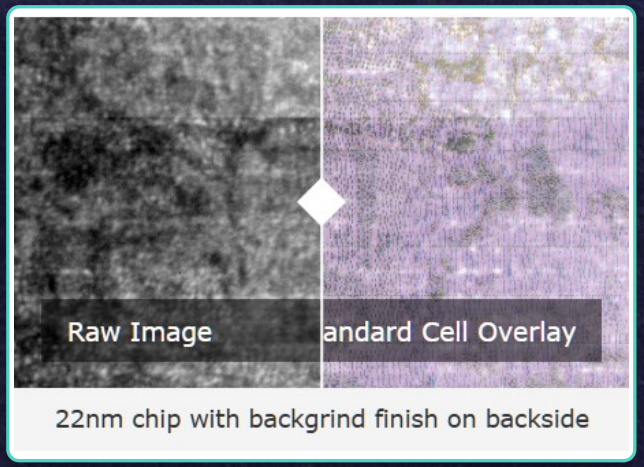


CHECK WHAT IS INSIDE A CHIP WITH INFRARED LIGHT

No lab, no damage: infrared through the back of the die.

A teardown costs a lab, weeks, and the chip. IRIS costs an LED and a camera, and the chip survives.





22nm chip with backgrind finish on backside

infrared
through the back of the die

angle
is the fingerprint

metal, not gates
the honest limit

Verification moves from “once, by a lab, in secret” to “any time, by you, at your desk”.

OSTROS: A WALLET YOU CAN REBUILD FROM SOURCE

Every layer is published, from the app down to the chip logic.

Rebuild the firmware from source and compare your hash with the one we publish.



- **companion app** published
- **applications** published
- **app framework** published
- **system services** published
- **Xous OS** published
- **drivers** published
- **bootloaders** published
- **boot0** published · burned in, cannot be reflashed
- **chip logic** published

built together

Baochip
betrusted · Xous
Ethereum Foundation · zknox
CrossBar

Nobody could have built this alone.

How AI accelerates DIY

Agents build the parts, proofs and dev kits close the gap.

Agents handle each component

- **Crypto & key derivation**
- **Transaction parsing**
- **UI & clear signing**
- **Drivers & transport**

→ **Mix**
integrate and test as one device

Prove the critical parts

Lean proofs of the critical code are getting easy to produce automatically.

AI-ready hardware

Development kits are now sold as AI ready, e.g. mosaico.ai.

FOUR DIY SIGNERS BUILT WITH AGENTS

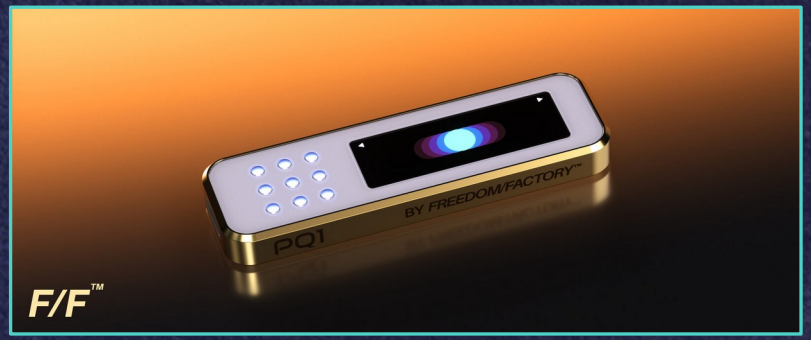
Different chips, stacks and origins: all mostly written by AI.

Share of commits co-authored by Claude, from each repository history.

Project	Chips	Stack	Based on	AI commits
PQ1	STM32U5 + Trust M + SE050	Rust	original code	**~2,000 / 2,828**
Wedgie	RP2040 Pico + Trust M	MicroPython, web	picowallet	**~980 / 998**
Ice	STM32U5 + SE050 + Trust M	C, tscircuit board	trezor-firmware	**285 / 286**
LeekWallet	ESP32-S3, no secure chip	C (ESP-IDF), Tauri	original code	**~540 / 696**

PQI

A post-quantum-only smart-account signer.



What it does differently

SPHINCS+ only, verified on-chain (ERC-4337)

Seed XOR-split across secure chips from two vendors

Firmware hash shown as words; Lean 4 proofs

How it is built

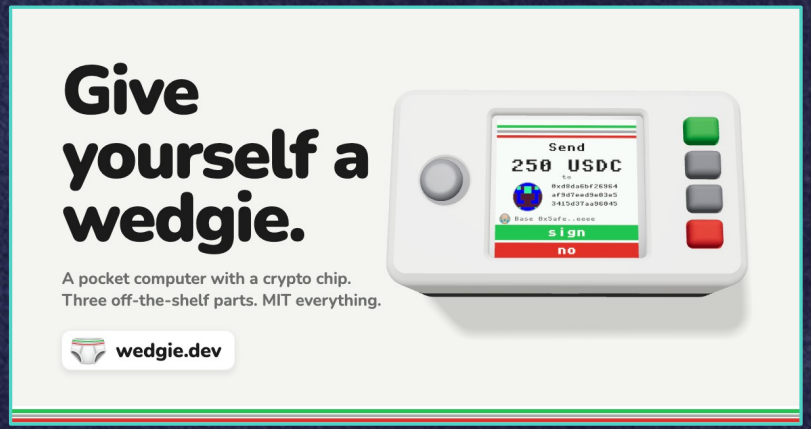
Rust no_std on STM32U585 TrustZone · QEMU · Foundry

Forked from / based on

Original code; SPHINCS+ verifier and Trezor tamper driver reused

WEDGIE

Three off-the-shelf parts, no soldering, apps from a shelf.



What it does differently

Generic parts: the order doesn't say 'wallet'

Signed apps, each pinned to a reviewed commit

Made for agents: skill file, emulator, virtual device

How it is built

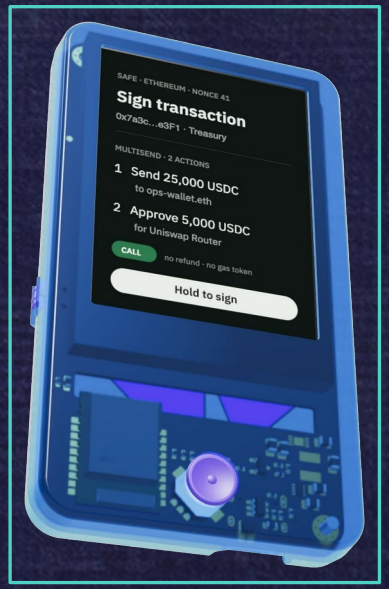
MicroPython firmware · TypeScript web flasher (WebSerial)

Forked from / based on

Grew out of picowallet (Austin Griffith), MIT licensed

ICE

A Safe signer you are meant to open.



What it does differently

Two secure chips from two vendors: SE050 + Trust M

Physical airgap switch, animated QR signing

Clear case + published Gerbers to check the board

How it is built

Board in tscircuit (TypeScript) + KiCad · firmware in Docker

Forked from / based on

Fork of trezor-firmware (custom board), synced weekly

LEEKWALLET

A $10 wallet that refuses to sign what it can't read.



What it does differently

~$10 of parts: ESP32-S3, OLED, no secure chip

Decodes calldata on device; unknown calls are refused

Air-gapped camera variant with EIP-4527 animated QR

How it is built

C on ESP-IDF (PlatformIO) · Tauri companion app

Forked from / based on

Original code; vendors trezor-crypto, quirc, Firefly display

How you can contribute

Open devices need more builders.

1

Alternative hardware

Build with different hardware components.

Avoid supply chain shocks

2

App store models

More applications outside of crypto.

Passkeys are the most popular alternative use so far



THANK YOU!

NICOLAS BACCA (BTCHIP)
Chef, zknox
@btchip